

# Topic 11 Assessment Report

Security, Rate Limits & Production Scaling

**Prepared by:** Shaik Mohammad Shaheed

**GitHub:** <https://github.com/shaikshahid777/retell-ai-topic-11-security-rate-limits-scaling>

**Report date:** 05 October 2026

| Configuration review                          | Status    |
|-----------------------------------------------|-----------|
| Dashboard settings reviewed and documented    | Completed |
| PII storage and redaction configured          | Completed |
| Keypad input detection configured             | Completed |
| Live load, rate-limit, webhook and call tests | Not run   |

Purpose: record the visible Retell AI dashboard configuration for Topic 11 and distinguish saved configuration from behavior that still needs approved testing.

## 1. Executive Summary

This report documents the security configuration reviewed for agent **Trainee\_Sarah\_Receptionist**. No live calls, API load tests, webhook tests, or simulations were run for this assessment.

**Evidence limitation:** a saved setting is not proof that runtime behavior has been tested. This report does not claim successful HTTP 429 responses, runtime PII/audio masking, or verified retention deletion.

## 2. Configuration Evidence

| Area                     | Observed / configured value                     | Status / notes               |
|--------------------------|-------------------------------------------------|------------------------------|
| Agent                    | Trainee_Sarah_Receptionist                      | Settings reviewed            |
| Data storage             | Everything except PII                           | Selected in dashboard        |
| Retention                | 30 days                                         | Deletion not tested          |
| PII redaction            | 14 categories configured                        | Runtime masking not tested   |
| Keypad / DTMF            | Enabled; timeout 2.5 sec; digit limit enabled   | No live test                 |
| API key                  | Masked Secret Key "Webhook", created 2026-09-29 | Not rotated; secret excluded |
| Public Keys              | No public keys visible                          | None created                 |
| Concurrent call limit    | 20                                              | Dashboard value              |
| Reserve inbound capacity | Not set                                         | Left unchanged               |
| Telephony CPS            | Telnyx 1; Twilio 1; Custom Telephony 1          | Dashboard values             |
| LLM token limit          | 32,768                                          | Dashboard value              |
| Webhook                  | webhook.site endpoint; timeout 5 sec            | Not tested                   |
| Stable Server            | Off                                             | Paid add-on not enabled      |
| Secure URLs              | Off                                             | Left unchanged               |

Values reflect dashboard details recorded during the walkthrough. Add your own screenshots to the repository if the course requires them.

## 3. Security Review

### API key handling

The existing Secret Key was left unchanged. Never publish secret values, credentials, or screenshots showing full keys in GitHub. Rotate/revoke keys only after checking dependencies and obtaining approval.

### PII handling and storage

Storage mode is "Everything except PII" and 14 redaction categories were configured. Transcript, audio, tool-argument, and dynamic-variable masking were not validated through a live call.

### Keypad / DTMF

User Keypad Input Detection is enabled, with a 2.5-second timeout and digit-limit control enabled. No live DTMF capture or masking test was run.

### Retention

The selected retention period is 30 days. Automatic deletion was not tested. Shorter retention settings may permanently remove data; do not change them just to produce evidence.

### Concurrency and scaling

The concurrent-call limit is 20. Reserve inbound capacity is not set, and concurrency burst remains disabled. The dashboard showed potential extra charges for burst capacity.

### Encryption and compliance

This report does not independently verify TLS versions or at-rest encryption algorithms. Confirm exact technical claims with current Retell documentation or support.

## 4. Rate Limits and HTTP 429

The course material mentions 100 requests per 10 seconds and HTTP 429. Treat this as course-provided context, not a verified current account limit. No rapid-request test was run. A production client should use bounded exponential backoff and respect a Retry-After header if supplied.

Do not send rapid requests merely to demonstrate a limit unless a supervisor approves the test and its impact.

## 5. Test Plan and Evidence Status

| Item              | Status                      | Safe next step                          |
|-------------------|-----------------------------|-----------------------------------------|
| API key screen    | Reviewed                    | Screenshot with secret masked           |
| PII settings      | Configured                  | Screenshot; no real PII                 |
| DTMF              | Configured; untested        | Synthetic digits only if approved       |
| Retention         | 30 days; deletion untested  | Document setting; do not force deletion |
| Concurrency       | Reviewed; load test not run | Approved staging test if required       |
| HTTP 429          | Not tested                  | Confirm current limit                   |
| Webhook/signature | Not tested                  | Controlled endpoint; verify server-side |
| Encryption claims | Not independently verified  | Official docs/support confirmation      |
| Loom demo         | Pending                     | Walkthrough without secrets             |

## 6. Screenshot Checklist

- API Keys page: name/date visible, full secret masked.
- Data Storage Settings: Everything except PII and 30-day retention.
- PII Redaction setup: selected categories visible; no customer data.
- Keypad settings: enabled status, timeout, digit limit.
- Settings → Limits: concurrency and telephony CPS values.
- Webhook settings: URL/timeout visible without clicking Test.
- Stable Server and Secure URLs current settings.

## 7. Assessment Checklist

- API key management reviewed; no secrets committed.
- PII storage mode and redaction categories configured.
- DTMF keypad detection configured.
- Retention window reviewed and set to 30 days.
- Concurrency and telephony CPS settings reviewed.
- Rate-limit behavior documented; no load test performed.
- Encryption claims limited to available evidence.
- Public GitHub README prepared.
- Screenshot evidence to be added by learner.
- Loom walkthrough video to be recorded by learner.

## 8. Limitations

This is a configuration-review report, not a penetration test or production certification. Live calls, simulations, API load tests, webhook delivery, runtime PII masking, and retention deletion were not performed. Keep these items pending unless approved tests are completed and documented.

Never include API keys, personal/customer data, or unredacted recordings in public repositories.

## 9. Official References

API key management: <https://docs.retellai.com/accounts/manage-api-keys>

API key overview: <https://docs.retellai.com/accounts/api-keys-overview>

Public keys: <https://docs.retellai.com/accounts/public-keys>

PII/privacy settings: <https://docs.retellai.com/accounts/privacy-disable>

**Concurrency:** <https://docs.retellai.com/deploy/concurrency>

**User keypad/DTMF:** <https://docs.retellai.com/build/user-dtmf>

**Data retention:** <https://docs.retellai.com/accounts/data-retention>

**Compliance:** <https://docs.retellai.com/general/compliance>

**Create phone call API:** <https://docs.retellai.com/api-references/create-phone-call>